

Task 8 Report (ID Sevasion)

Objective

To learn how Intrusion Detection Systems (IDS) detect network and web-layer attacks and to practice common IDS evasion techniques in a safe, legal lab environment (TryHackMe). The goal was to enumerate the target, trigger IDS alerts with baseline payloads, attempt evasion techniques, observe which technique bypassed detection, and capture the lab flag.

Tools Used

- TryHackMe AttackBox (browser-based) / Kali Linux
- nmap
- curl
- hping3 (optional)
- scapy (optional)
- tcpdump / Wireshark (optional)
- Burp Suite (optional)
- Nikto / Gobuster (optional for web enumeration)

Environment

- TryHackMe Room: <https://tryhackme.com/room/idsevasion>
- Target machine IP: 10.201.110.164
- Attack platform: TryHackMe AttackBox (browser) / Kali VM
- Network: TryHackMe isolated lab network (no real-world traffic)
- Notes: All activities documented in this report were performed inside the TryHackMe lab and used only test accounts and resources provided by the room.

Procedure

1. **Joined the TryHackMe room:** <https://tryhackme.com/room/idsevasion>
2. Started the target virtual machine and noted the IP address.
3. Scanned the target using nmap to find open ports.
4. Visited the website on port 80 (if present) to identify services.
5. Observed IDS alerts when sending normal requests.
6. Tested several evasion techniques (URL encoding, comment obfuscation, fragmentation, slow requests).
7. Captured the flag once an evasion method succeeded.

Phishing simulation plan x TryHackMe | Intrusion Detec... x Pull requests - geethika3076/Cy... x TryHackMe | Dashboard x 10.201.110.164 x + x

tryhackme.com/room/ids evasion

Room progress (4%)

Either way, once an incident is detected, the IDS will generate an alert and will then forward it further up the security chain to log aggregation or data visualisation platforms like Graylog or the ELK Stack. Some IDS may also feature some form of intrusion prevention technology and may automatically respond to the incident.

Two signature-based IDS are attached to this demo; Suricata, a network-based IDS (NIDS), and Wazuh, a host-based IDS (HIDS). Both of these IDS implement the same overarching signature detection methodology; however, their overall behaviour and the types of attacks that they can detect differ greatly. We will cover the exact differences in more detail in the following tasks.

Answer the questions below

What IDS detection methodology relies on rule sets?

signature-based detection ✓ Correct Answer

Task 3 Network-based IDS (NIDS) ✓

Task 4 Reconnaissance and Evasion Basics ✓

Task 5 Further Reconnaissance Evasion ✓

Task 6 Open-source Intelligence ✓

Task 7 Rulesets ✓

28°C Mostly cloudy

Phishing simulation plan x TryHackMe | Intrusion Detec... x Pull requests - geethika3076/Cy... x TryHackMe | Dashboard x 10.201.110.164 x + x

tryhackme.com/room/ids evasion

Room progress (17%)

alert is triggered but, its severity is reduced. In some scenarios, complete evasion may be the only option for example, if valuable assets are be just as good as low severity IDS alerts particularly from, NIDS are much less likely to be investigated, or even forwarded further up the al by the scoring system as it will take the reliability of each of the attached IDS into account when scoring alerts.

Answer the questions below

What scale is used to measure alert severity in Suricata? (1-5)

1-3 ✓ Correct Answer Hint

How many services is smap able to fully recognise when the service scan (-s0) is performed?

3 ✓ Correct Answer Hint

32/483 Points Earned! Levelling up in progress...

4/23 Questions answered! Levelling up in progress...

Task 5 Further Reconnaissance Evasion ✓

Task 6 Open-source Intelligence ✓

Task 7 Rulesets ✓

Task 8 Host-Based IDS (HIDS) ✓

Tom of rain tonight

Phishing simulation plan x TryHackMe | Intrusion Detec... x Pull requests - geethika3076/Cy... x TryHackMe | Dashboard x 10.201.110.164 x + x

tryhackme.com/room/ids evasion

Room progress (30%)

Technology packages are more intrusive, taking over some form of intranet or internet traffic. For applied the number of layers to desktop devices and network routers. It is important to note that this takes too long to process all of the alerts generated by aggressive scans.

More practical options from the field of open-source intelligence may also be available and will be covered in the next task.

Answer the questions below

Nikto, should find an interesting path when the first scan is performed, what is it called?

/login ✓ Correct Answer

What value is used to toggle denial of service vectors when using scan tuning (-T) in nikto?

6 ✓ Correct Answer Hint

Which flags are used to modify the request spacing in nikto? Use commas to separate the flags in your answer.

S,A,B ✓ Correct Answer Hint

7/23 Questions answered! Levelling up in progress...

56/483 Points Earned! Levelling up in progress...

Task 6 Open-source Intelligence ✓

Task 7 Rulesets ✓

Task 8 Host-Based IDS (HIDS) ✓

Light rain All night

Phishing simulation plan x TryHackMe | Intrusion Detec... x Pull requests - geethika3076/Cy... x TryHackMe | Dashboard x 10.201.110.164 x + x

tryhackme.com/room/ids evasion

Room progress (47%)

Additional information on the tools used by the target may be available in job listings

For this demo, have a look around the "public" facing site and see how much information you can acquire.

Answer the questions below

What version of Grafana is the server running?

8.2.5 ✓ Correct Answer Hint

What is the ID of the severe CVE that affects this version of Grafana?

CVE-2021-43798 ✓ Correct Answer Hint

If this server was publicly available, What site might have information on its services already?

shodan ✓ Correct Answer

How would we search the site "example.com" for pdf files, using advanced Google search tags?

site:example.com filetype:pdf ✓ Correct Answer

Task 7 Rulesets ✓

Rain coming in about 2.5 hours

